



Unknown Project

Security Assessment Report

2026-04-10

HIGH RISK

22 findings identified

0

CRITICAL

10

HIGH

12

MEDIUM

0

LOW

Disclaimer

Assessment Notice

This security assessment was generated using tachi, an automated threat modeling toolkit. The analysis applies STRIDE methodology and AI-specific threat categories to the provided architecture description. Results reflect the automated analysis and should be validated by qualified security professionals.

Scope Limitation

This assessment is limited to the architecture description provided at the time of analysis. It does not cover runtime behavior, implementation-level vulnerabilities, or threats arising from future system changes. The assessment scope is defined in the Assessment Scope section of this report.

Recommendation

This automated assessment should complement, not replace, manual security review by qualified professionals. Organizations should conduct periodic penetration testing, code review, and architecture review in addition to automated threat modeling.

Confidentiality

This document contains sensitive security assessment information. Distribution should be limited to authorized personnel with a legitimate need to review the security posture of the assessed system. Do not share externally without appropriate authorization.

Table of Contents

Disclaimer 2

Table of Contents 3

Risk Methodology 4

Assessment Scope 8

Executive Summary 10

Executive Threat Architecture 11

Risk Reduction Funnel 42

Risk Summary Dashboard 43

System Architecture 44

MAESTRO Layer Analysis 45

Findings Detail — Residual Risk 49

Control Coverage 53

Remediation Roadmap 54

Risk Methodology

Threat Identification

This assessment uses STRIDE threat modeling combined with AI-specific threat categories to provide comprehensive coverage of both traditional and emerging attack vectors.

STRIDE Categories

Spoofing — Impersonating a user, component, or system to gain unauthorized access.

Tampering — Unauthorized modification of data in transit, at rest, or in processing.

Repudiation — Performing actions without adequate logging or accountability trails.

Information Disclosure — Exposing sensitive data to unauthorized parties through leaks or side channels.

Denial of Service — Degrading or disrupting system availability through resource exhaustion or abuse.

Elevation of Privilege — Gaining higher access rights than authorized through exploitation of trust boundaries.

AI-Specific Categories

Prompt Injection — Manipulating AI model behavior through crafted inputs that override system instructions.

Tool Abuse — Exploiting AI agent tool access to perform unintended or unauthorized operations.

Agent Autonomy — Risks from AI agents acting beyond their intended scope without adequate human oversight.

Data Poisoning — Corrupting training data or context to degrade model accuracy or introduce bias.

Model Theft — Unauthorized extraction or replication of proprietary model weights or behavior.

Probability x Impact Matrix

Each identified threat is assessed for probability of occurrence and potential impact. The intersection determines the overall severity rating used throughout this report.

Impact / Probability	Rare	Unlikely	Possible	Likely	Almost Certain
Critical	H	H	C	C	C
High	M	M	H	C	C
Moderate	L	M	M	H	H
Low	L	L	M	M	H
Negligible	L	L	L	M	M

■ C = Critical ■ H = High ■ M = Medium ■ L = Low

Quantitative Risk Scoring

When quantitative data is available, each threat receives a composite risk score derived from four independent dimensions. This provides a more granular risk ranking than severity alone.

Scoring Dimensions

Dimension	Range	Description
CVSS 3.1 Base Score	0 – 10	Industry-standard vulnerability severity rating based on attack vector, complexity, and impact.
Exploitability	0 – 10	Ease of exploitation considering required skills, tooling availability, and attack complexity.
Scalability	0 – 10	Potential for automated or mass exploitation across multiple targets or instances.
Reachability	0 – 10	Network accessibility of the vulnerable component from the attacker's perspective.

Composite Score Formula

The composite risk score is a weighted average of the four dimensions:

$$\text{Composite} = (\text{CVSS} \times 0.40) + (\text{Exploitability} \times 0.25) + (\text{Scalability} \times 0.20) + (\text{Reachability} \times 0.15)$$

Weights reflect the relative importance of each dimension: CVSS captures inherent severity (40%), exploitability measures practical attack feasibility (25%), scalability accounts for blast radius (20%), and reachability assesses network exposure (15%).

Compensating Control Analysis

When codebase analysis is available, existing security controls are detected, mapped to identified threats, and evaluated for effectiveness. This provides a residual risk assessment that accounts for defenses already in place.

Analysis Process

1. **Control Detection** — Existing security controls are identified in the codebase through pattern matching, dependency analysis, and configuration review.
2. **Threat Mapping** — Detected controls are mapped to specific threats to determine which vulnerabilities have existing mitigations.
3. **Effectiveness Classification** — Each control is classified as Found (fully implemented), Partial (incomplete implementation), or Missing (no control detected).
4. **Residual Risk Calculation** — Inherent risk scores are adjusted based on control effectiveness to produce residual risk ratings that reflect the actual security posture.

Assessment Overview

Assessment Scope

7 Components

13 Data Flows

3 Trust Boundaries

Components Analyzed

Name	Type	Description
User	External Entity	End user submitting prompts and receiving responses via HTTPS
Guardrails Service	Process	Input validation and filtering service that screens user prompts before forwarding to orchestration
LLM Agent Orchestrator	Process	Central orchestration process that dispatches LLM inference, retrieves context from the knowledge base, and coordinates tool calls via MCP
MCP Tool Server	Process	Model Context Protocol server that executes tool calls on behalf of the orchestrator and interfaces with external APIs
Knowledge Base	Data Store	Vector database storing document embeddings for retrieval-augmented generation (RAG) context
Audit Logger	Data Store	Append-only log store capturing decision logs, tool execution events, and filtering events for accountability
External API	External Entity	Third-party API services accessed by the MCP Tool Server for external data and actions

Data Flows

Source	Destination	Data	Protocol
User	Guardrails Service	Prompt / Query	HTTPS
Guardrails Service	LLM Agent Orchestrator	Validated Prompt	Internal RPC
Guardrails Service	User	Rejected Prompt + Reason	HTTPS
LLM Agent Orchestrator	Knowledge Base	Context Retrieval Query	Vector Search
Knowledge Base	LLM Agent Orchestrator	Retrieved Documents	Vector Search
LLM Agent Orchestrator	MCP Tool Server	Tool Call Request	JSON-RPC
MCP Tool Server	LLM Agent Orchestrator	Tool Result	JSON-RPC
MCP Tool Server	External API	API Request	HTTPS
External API	MCP Tool Server	API Response	HTTPS
LLM Agent Orchestrator	User	Response	HTTPS

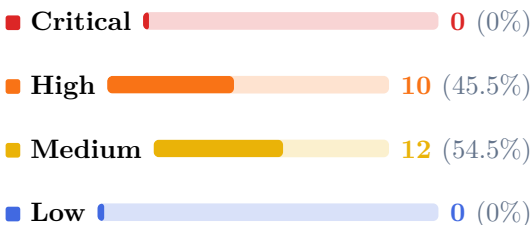
Source	Destination	Data	Protocol
LLM Agent Orchestrator	Audit Logger	Decision Log Entry	Internal
MCP Tool Server	Audit Logger	Tool Execution Log	Internal
Guardrails Service	Audit Logger	Filtering Event Log	Internal

Trust Boundaries

Zone	Trust Level	Components
User Zone	Untrusted	User
Application Zone	Trusted	Guardrails Service, LLM Agent Orchestrator, MCP Tool Server, Knowledge Base, Audit Logger
External Services	Untrusted	External API

Executive Summary

Severity Distribution 22 findings total



Component Distribution

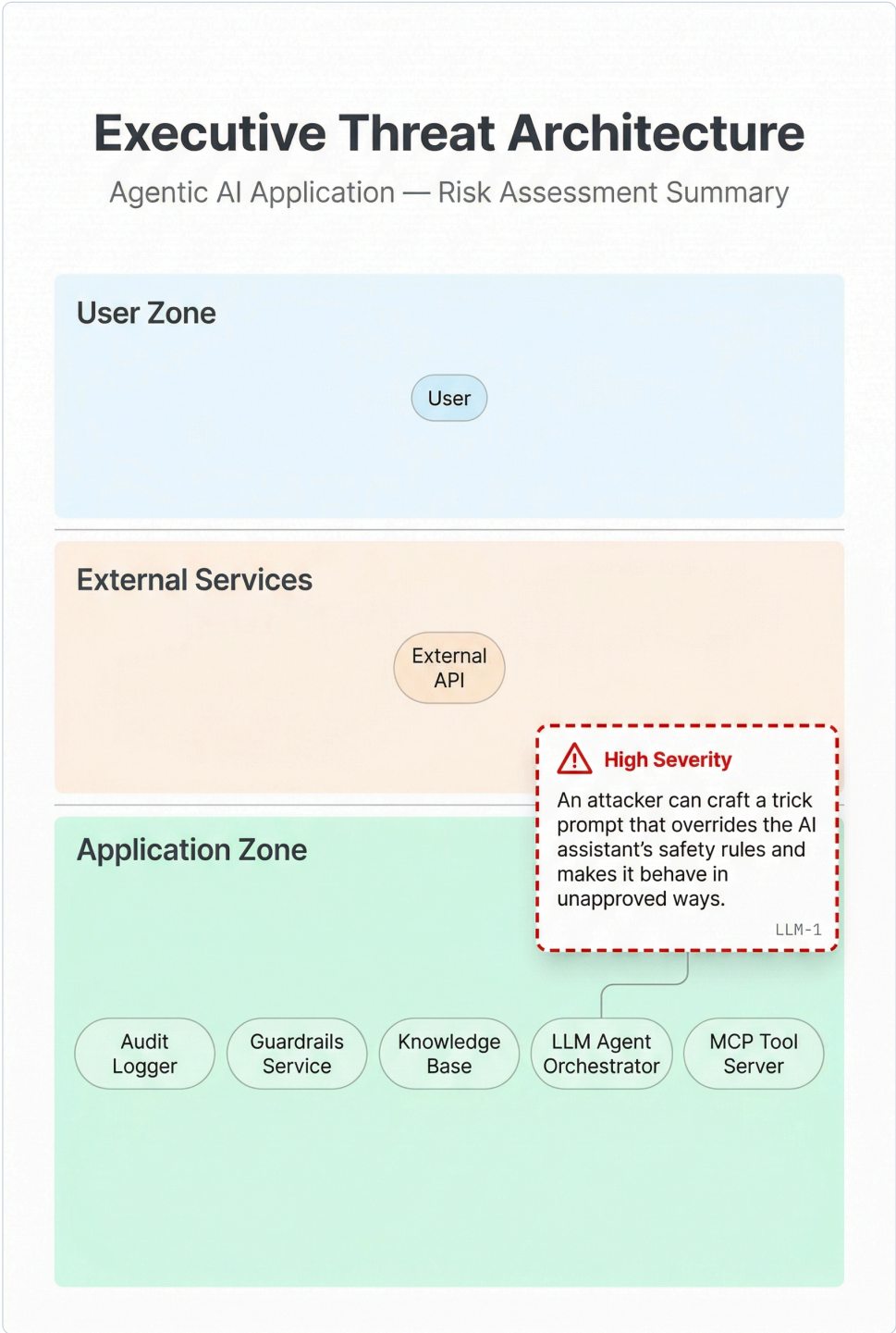
Component	Findings
LLM Agent Orchestrator	10
MCP Tool Server	4
Guardrails Service	2
Knowledge Base	2
User	2
Audit Logger	1
External API	1

Assessment Summary

The system presents an ****elevated risk posture**** with 8 Critical and 14 High findings requiring immediate attention. The LLM Agent Orchestrator is the highest-risk component, concentrating 11 of 34 findings across all threat categories including AI-specific threats. Positively, the architecture includes a dedicated Guardrails Service for input filtering and an Audit Logger for centralized logging – these components, once hardened, provide strong foundations for defense-in-depth.

- **Direct Prompt Injection (LLM-1, Critical)**:** Adversarial prompts can override the Orchestrator's system instructions, potentially causing harmful content generation, data disclosure, or unauthorized actions. This is the most accessible attack vector requiring no special access.
 - **Unauthorized Consequential Actions (AG-1, Critical)**:** The Orchestrator can execute irreversible external operations (API calls, data writes) without human approval, meaning a single misinterpreted instruction could cause permanent data loss or financial damage.
 - **Tool Access Without Authorization (E-2, E-3, AG-3, Critical)**:** Neither the Orchestrator nor the MCP Tool Server enforces role-based access control on tool dispatch, allowing standard users to invoke privileged operations including data exports and configuration changes.
 - **Service Impersonation (S-3, Critical)**:** The JSON-RPC channel between the Orchestrator and MCP Tool Server lacks mutual authentication, enabling an attacker to forge tool call requests by impersonating the Orchestrator.
 - **Entry Point Denial of Service (D-1, D-2, Critical)**:** Both the Guardrails Service and the Orchestrator lack rate limiting and input size caps, enabling an attacker to exhaust compute resources with high-volume or maximum-length requests.
- **Implement role-based access control (RBAC)**** on all tool dispatch paths in both the Orchestrator and MCP Tool Server before deployment.
 - **Deploy structured prompt templates**** with explicit boundary enforce

Executive Threat Architecture



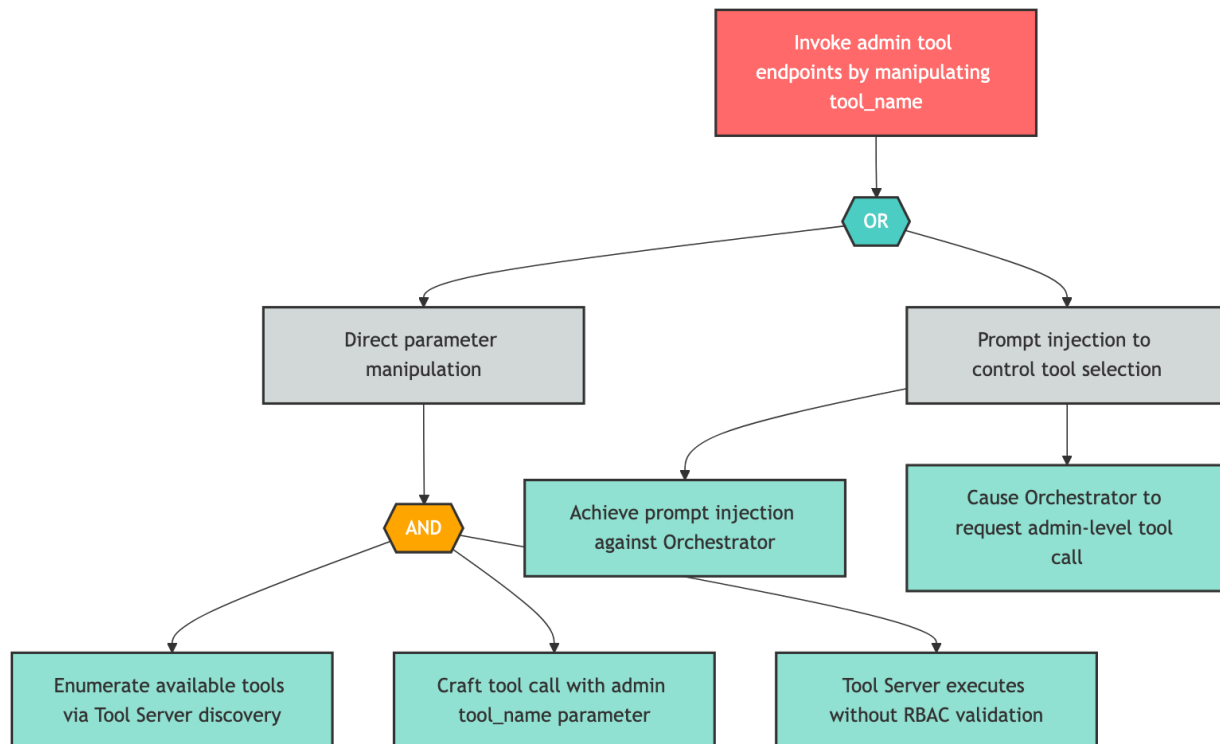
Layered system architecture with critical and high severity threats annotated as narrative callouts. This visualization highlights where the most exposed components sit in the system and what kind of attack each layer is most vulnerable to.

Attack Path Analysis

Attack Path Analysis

CRITICAL E-3 — Administrative Tool Access via Parameter Manipulation

Component: MCP Tool Server



An attacker targets MCP Tool Server by attempting to invoke admin tool endpoints by manipulating `tool_name`. The attack proceeds through combinations of several attack paths. Required attacker actions include "Enumerate available tools via Tool Server discovery", "Craft tool call with admin `tool_name` parameter", "Tool Server executes without RBAC validation", and 2 additional actions.

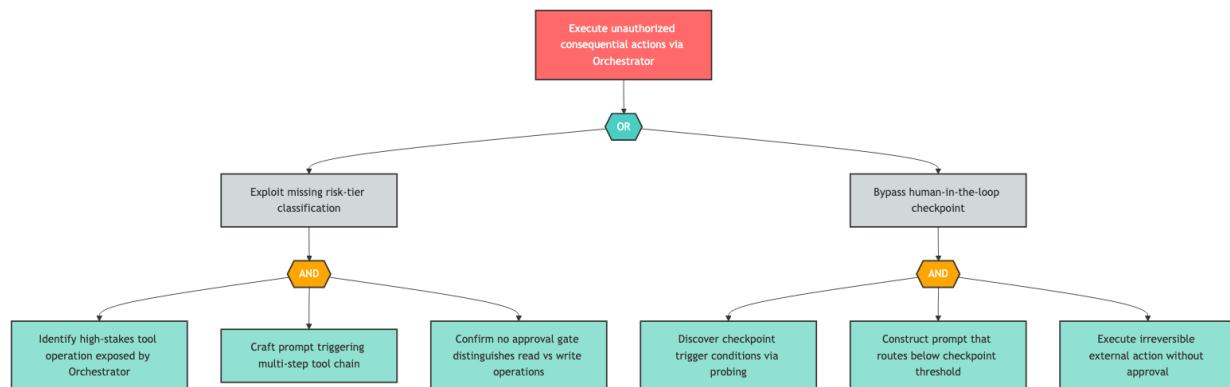
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH AG-1 — Autonomous Consequential Action Execution

Component: LLM Agent Orchestrator



An attacker targets LLM Agent Orchestrator by attempting to execute unauthorized consequential actions via orchestrator. The attack proceeds through combinations of several attack paths. Required attacker actions include "Identify high-stakes tool operation exposed by Orchestrator", "Craft prompt triggering multi-step tool chain", "Confirm no approval gate distinguishes read vs write operations", and 3 additional actions.

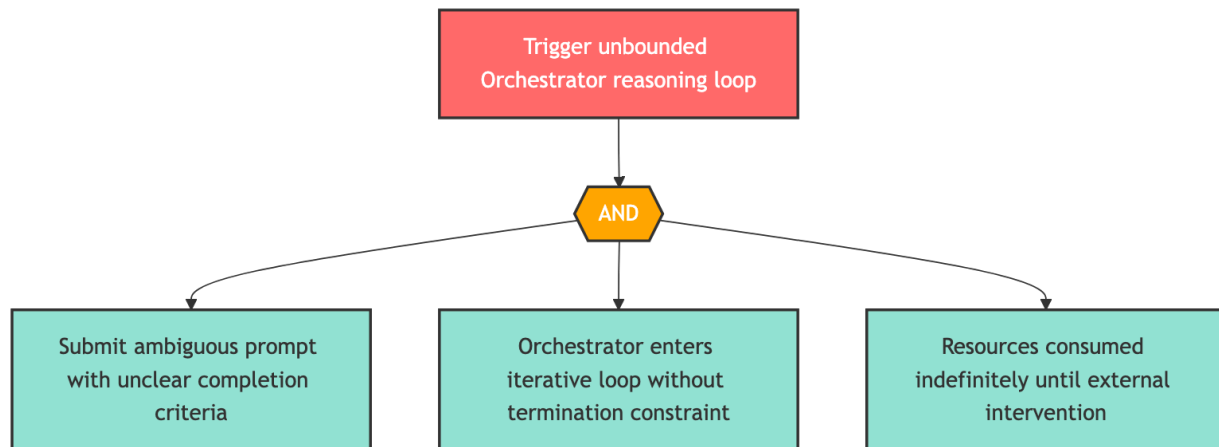
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH AG-2 — Unbounded Agent Reasoning Loop

Component: LLM Agent Orchestrator



An attacker targets LLM Agent Orchestrator by attempting to trigger unbounded orchestrator reasoning loop. The attack proceeds through all of several attack paths. Required attacker actions include "Submit ambiguous prompt with unclear completion criteria", "Orchestrator enters iterative loop without termination constraint", "Resources consumed indefinitely until external intervention".

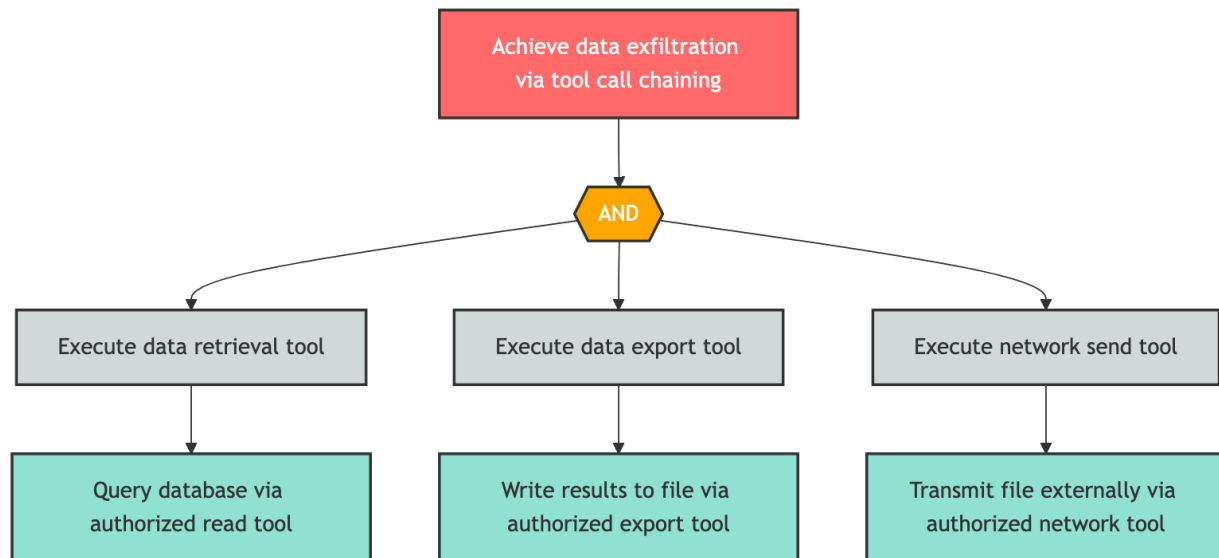
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH AG-4 — Capability Escalation via Tool Chaining

Component: MCP Tool Server



An attacker targets MCP Tool Server by attempting to achieve data exfiltration via tool call chaining. The attack proceeds through all of several attack paths. Required attacker actions include "Query database via authorized read tool", "Write results to file via authorized export tool", "Transmit file externally via authorized network tool".

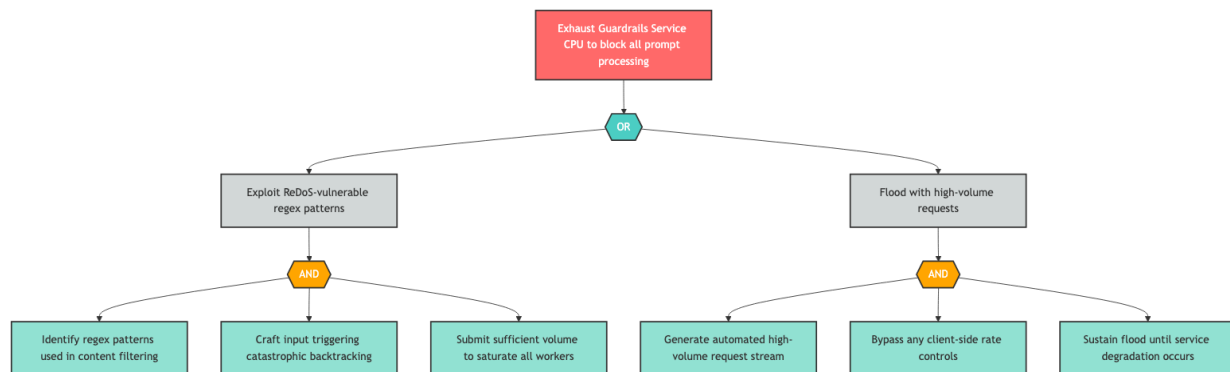
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH D-1 — Guardrails Service Resource Exhaustion

Component: Guardrails Service



An attacker targets Guardrails Service by attempting to exhaust guardrails service cpu to block all prompt processing. The attack proceeds through combinations of several attack paths. Required attacker actions include "Identify regex patterns used in content filtering", "Craft input triggering catastrophic backtracking", "Submit sufficient volume to saturate all workers", and 3 additional actions.

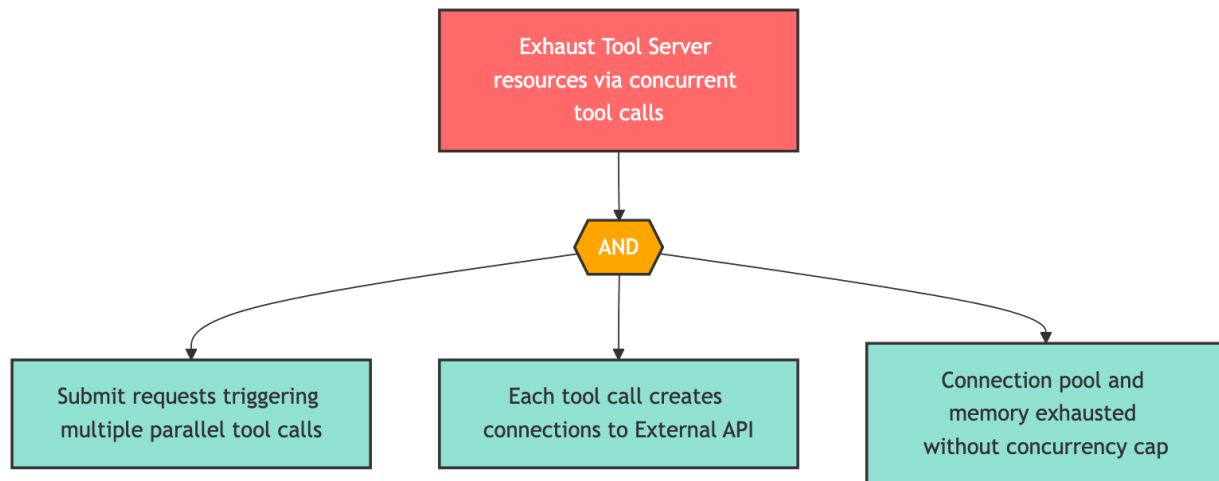
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH D-3 — Tool Server Concurrent Execution Exhaustion

Component: MCP Tool Server



An attacker targets MCP Tool Server by attempting to exhaust tool server resources via concurrent tool calls. The attack proceeds through all of several attack paths. Required attacker actions include "Submit requests triggering multiple parallel tool calls", "Each tool call creates connections to External API", "Connection pool and memory exhausted without concurrency cap".

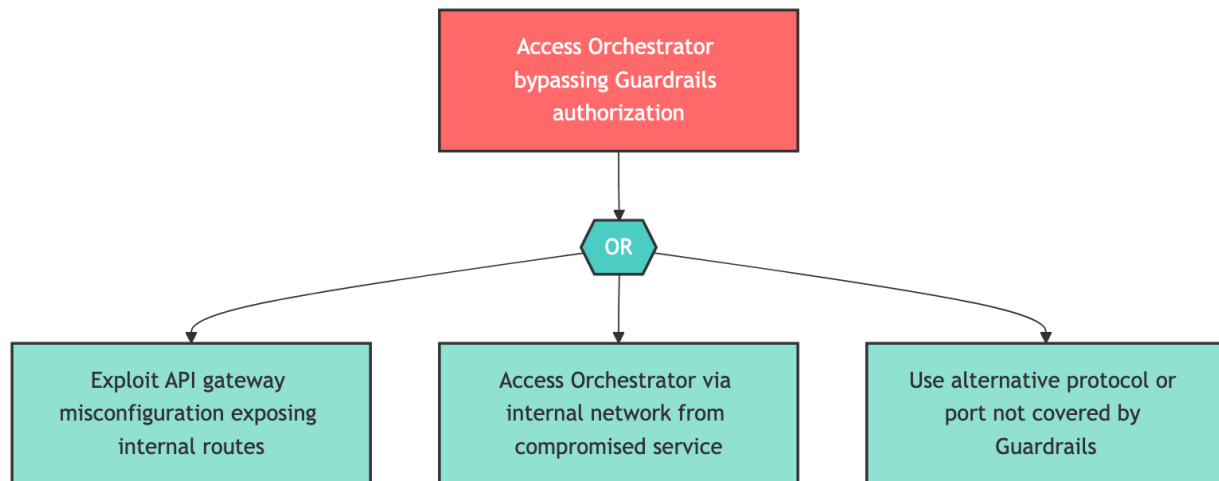
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH E-1 — Guardrails Bypass via Alternate Route

Component: Guardrails Service



An attacker targets Guardrails Service by attempting to access orchestrator bypassing guardrails authorization. The attack proceeds through any of several attack paths. Required attacker actions include "Exploit API gateway misconfiguration exposing internal routes", "Access Orchestrator via internal network from compromised service", "Use alternative protocol or port not covered by Guardrails".

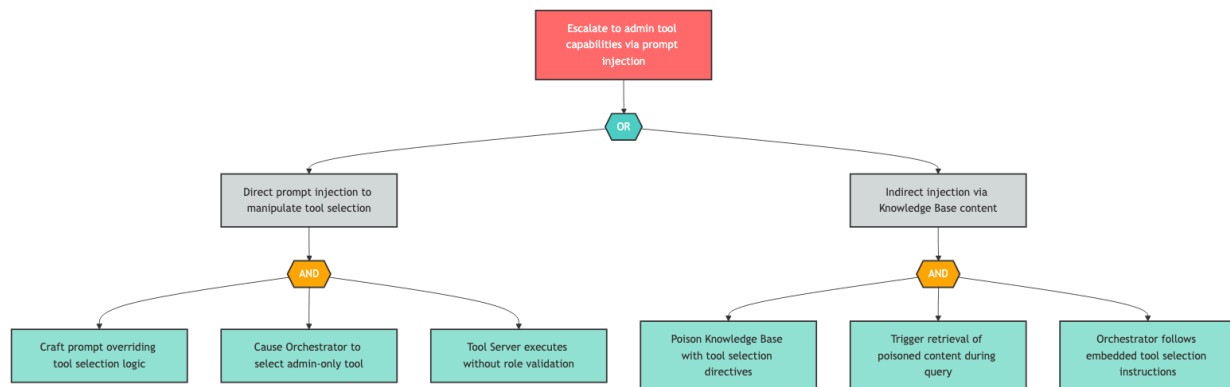
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH E-2 — Privilege Escalation via Tool Selection Manipulation

Component: LLM Agent Orchestrator



An attacker targets LLM Agent Orchestrator by attempting to escalate to admin tool capabilities via prompt injection. The attack proceeds through combinations of several attack paths. Required attacker actions include "Craft prompt overriding tool selection logic", "Cause Orchestrator to select admin-only tool", "Tool Server executes without role validation", and 3 additional actions.

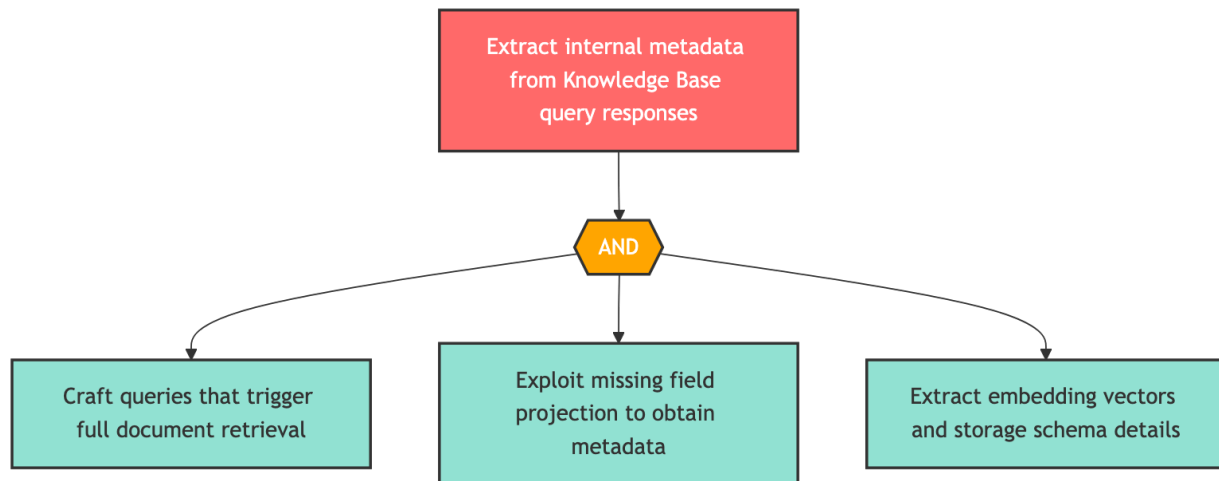
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH I-4 — Knowledge Base Metadata Exposure

Component: Knowledge Base



An attacker targets Knowledge Base by attempting to extract internal metadata from knowledge base query responses. The attack proceeds through all of several attack paths. Required attacker actions include "Craft queries that trigger full document retrieval", "Exploit missing field projection to obtain metadata", "Extract embedding vectors and storage schema details".

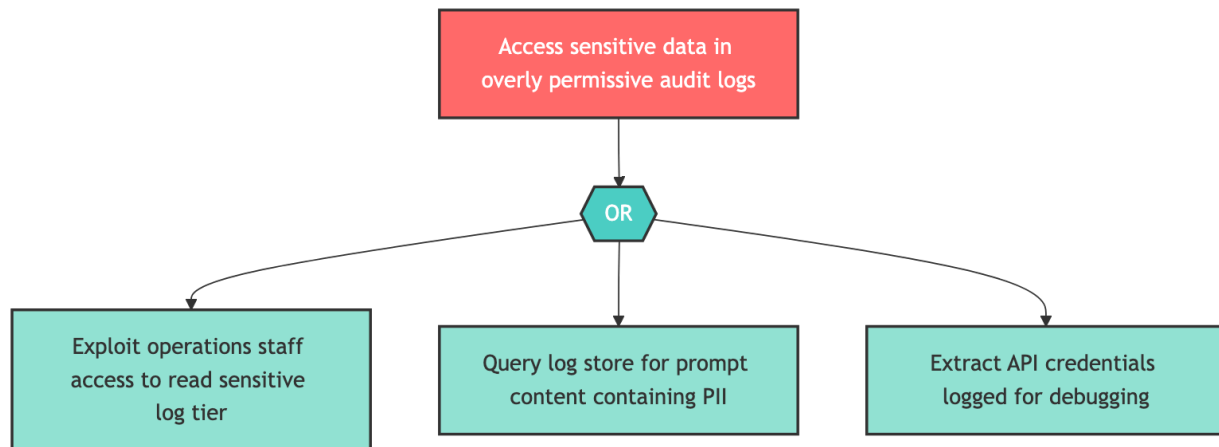
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH I-5 — Sensitive Data in Audit Logs

Component: Audit Logger



An attacker targets Audit Logger by attempting to access sensitive data in overly permissive audit logs. The attack proceeds through any of several attack paths. Required attacker actions include "Exploit operations staff access to read sensitive log tier", "Query log store for prompt content containing PII", "Extract API credentials logged for debugging".

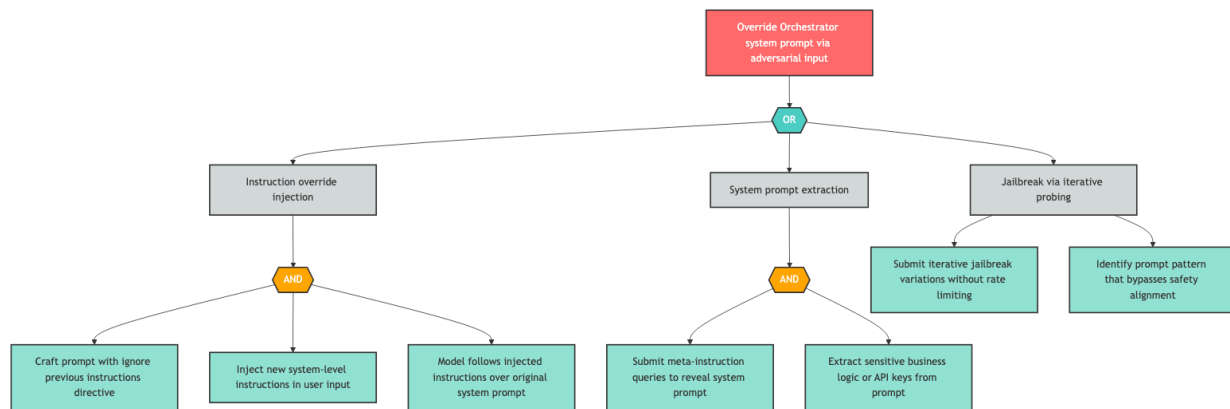
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH LLM-1 — Direct Prompt Injection

Component: LLM Agent Orchestrator



An attacker targets LLM Agent Orchestrator by attempting to override orchestrator system prompt via adversarial input. The attack proceeds through combinations of several attack paths. Required attacker actions include "Craft prompt with ignore previous instructions directive", "Inject new system-level instructions in user input", "Model follows injected instructions over original system prompt", and 4 additional actions.

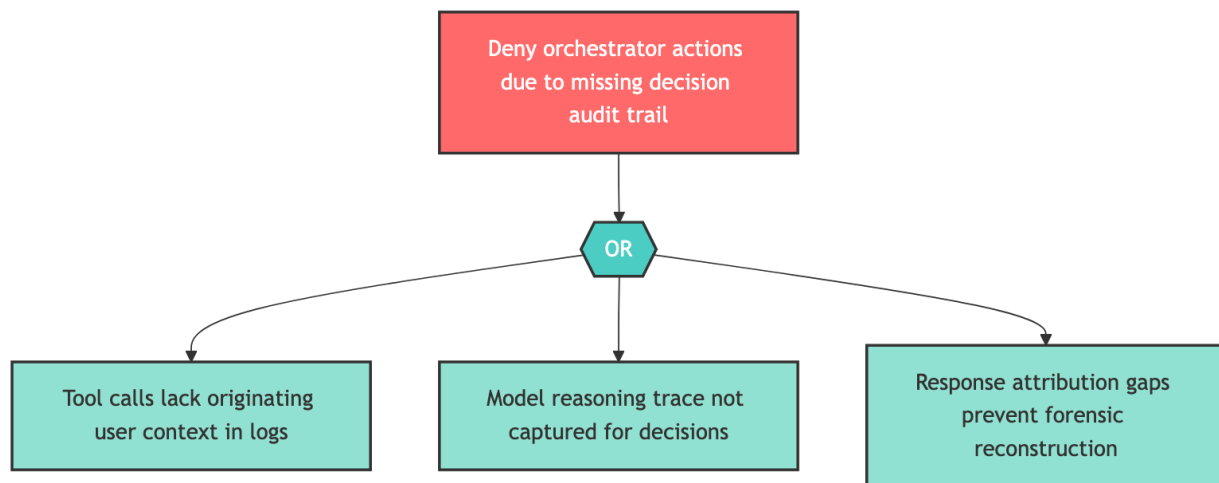
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH R-3 — Missing Decision Chain Audit Trail

Component: LLM Agent Orchestrator



An attacker targets LLM Agent Orchestrator by attempting to deny orchestrator actions due to missing decision audit trail. The attack proceeds through any of several attack paths. Required attacker actions include "Tool calls lack originating user context in logs", "Model reasoning trace not captured for decisions", "Response attribution gaps prevent forensic reconstruction".

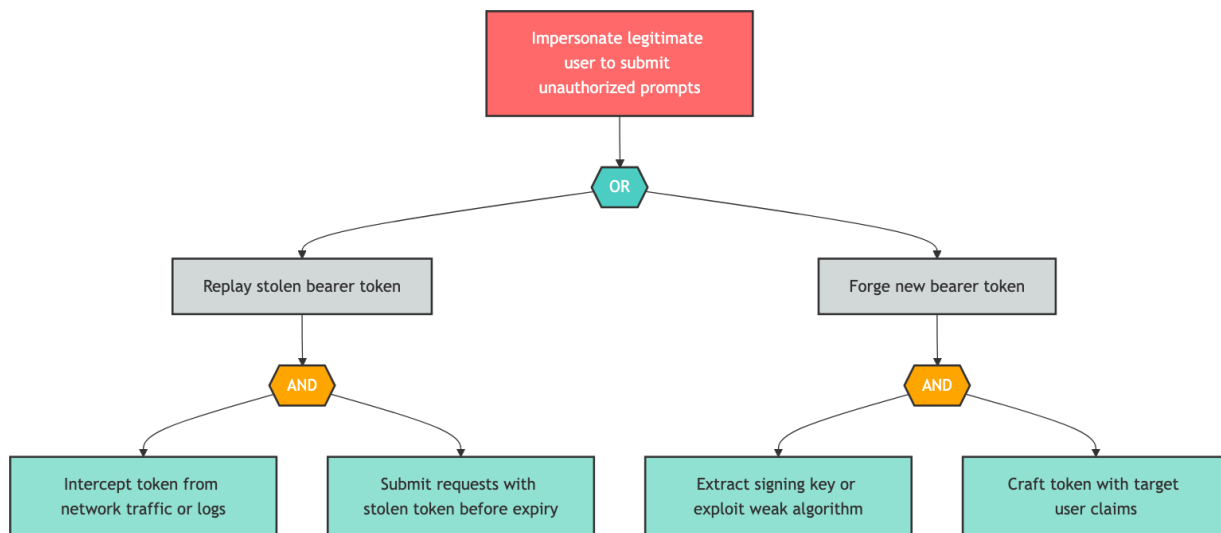
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH S-1 — User Identity Spoofing via Token Replay

Component: User



An attacker targets User by attempting to impersonate legitimate user to submit unauthorized prompts. The attack proceeds through combinations of several attack paths. Required attacker actions include "Intercept token from network traffic or logs", "Submit requests with stolen token before expiry", "Extract signing key or exploit weak algorithm", and 1 additional actions.

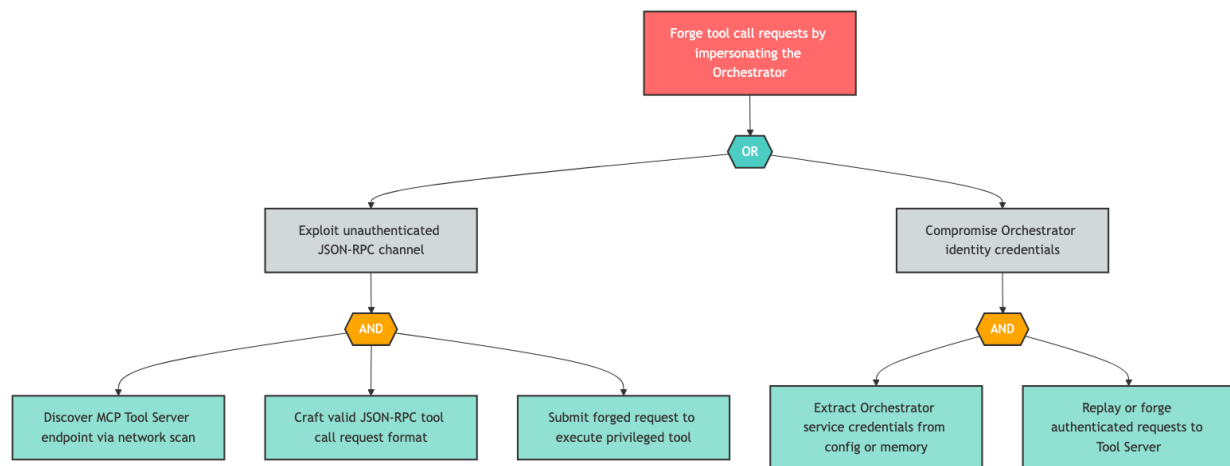
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH S-3 — Orchestrator Impersonation on JSON-RPC Channel

Component: LLM Agent Orchestrator



An attacker targets LLM Agent Orchestrator by attempting to forge tool call requests by impersonating the orchestrator. The attack proceeds through combinations of several attack paths. Required attacker actions include "Discover MCP Tool Server endpoint via network scan", "Craft valid JSON-RPC tool call request format", "Submit forged request to execute privileged tool", and 2 additional actions.

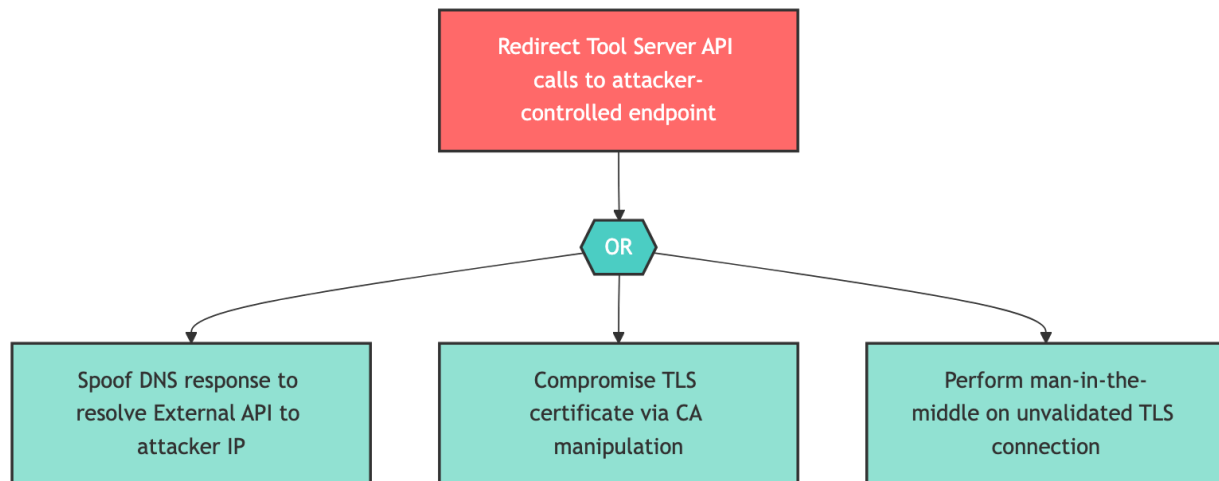
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH S-4 — DNS Spoofing to Redirect External API Calls

Component: MCP Tool Server



An attacker targets MCP Tool Server by attempting to redirect tool server api calls to attacker-controlled endpoint. The attack proceeds through any of several attack paths. Required attacker actions include "Spooft DNS response to resolve External API to attacker IP", "Compromise TLS certificate via CA manipulation", "Perform man-in-the-middle on unvalidated TLS connection".

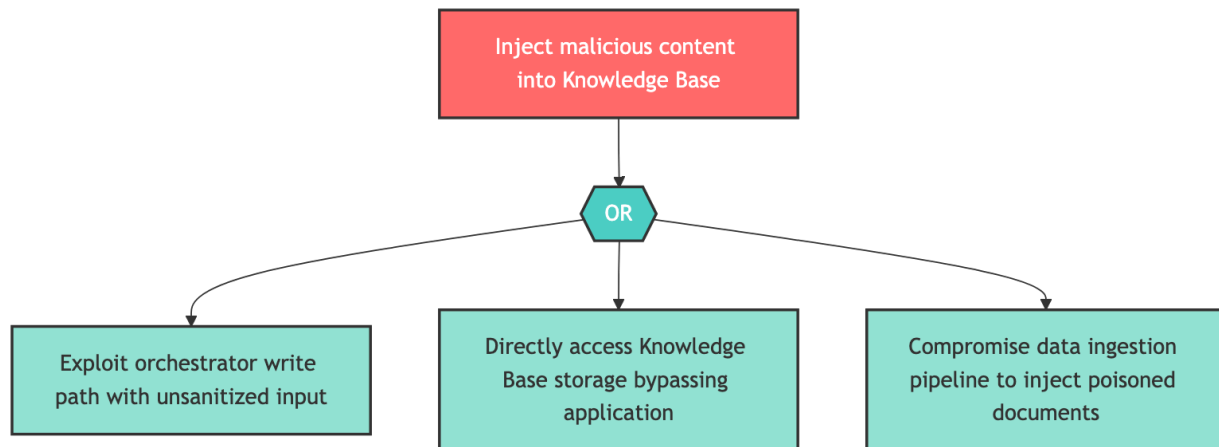
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH T-4 — Knowledge Base Content Poisoning

Component: Knowledge Base



An attacker targets Knowledge Base by attempting to inject malicious content into knowledge base. The attack proceeds through any of several attack paths. Required attacker actions include "Exploit orchestrator write path with unsanitized input", "Directly access Knowledge Base storage bypassing application", "Compromise data ingestion pipeline to inject poisoned documents".

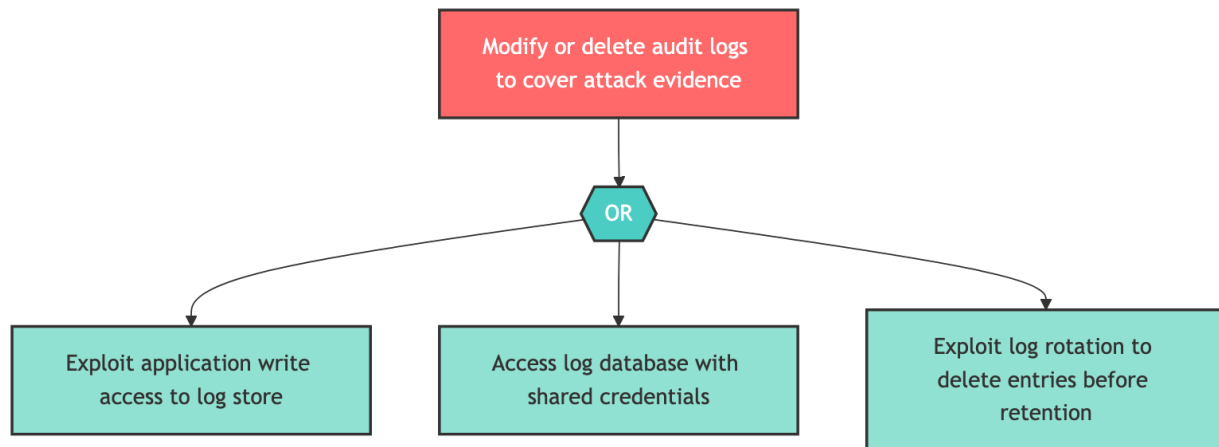
Remediation Steps

- Review and implement appropriate security controls.

Attack Path Analysis

HIGH T-5 — Audit Log Tampering

Component: Audit Logger



An attacker targets Audit Logger by attempting to modify or delete audit logs to cover attack evidence. The attack proceeds through any of several attack paths. Required attacker actions include "Exploit application write access to log store", "Access log database with shared credentials", "Exploit log rotation to delete entries before retention".

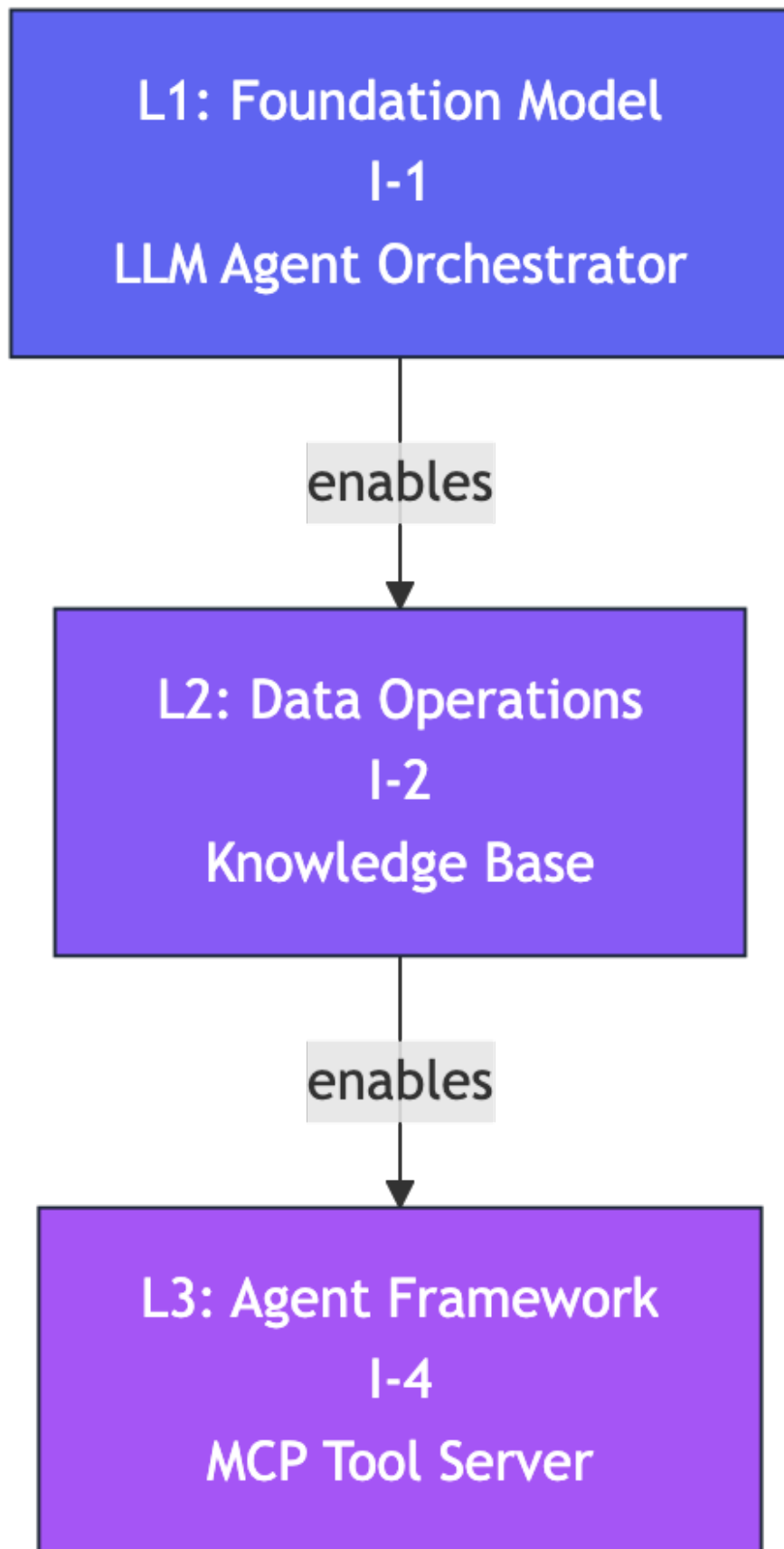
Remediation Steps

- Review and implement appropriate security controls.

Cross-Layer Attack Chain Analysis

Cross-Layer Attack Chain Analysis

CRITICAL CHAIN-001 L1 → L2 → L3 **Information Disclosure Cascade:
Foundation Model to Data Operations to Agent Framework**



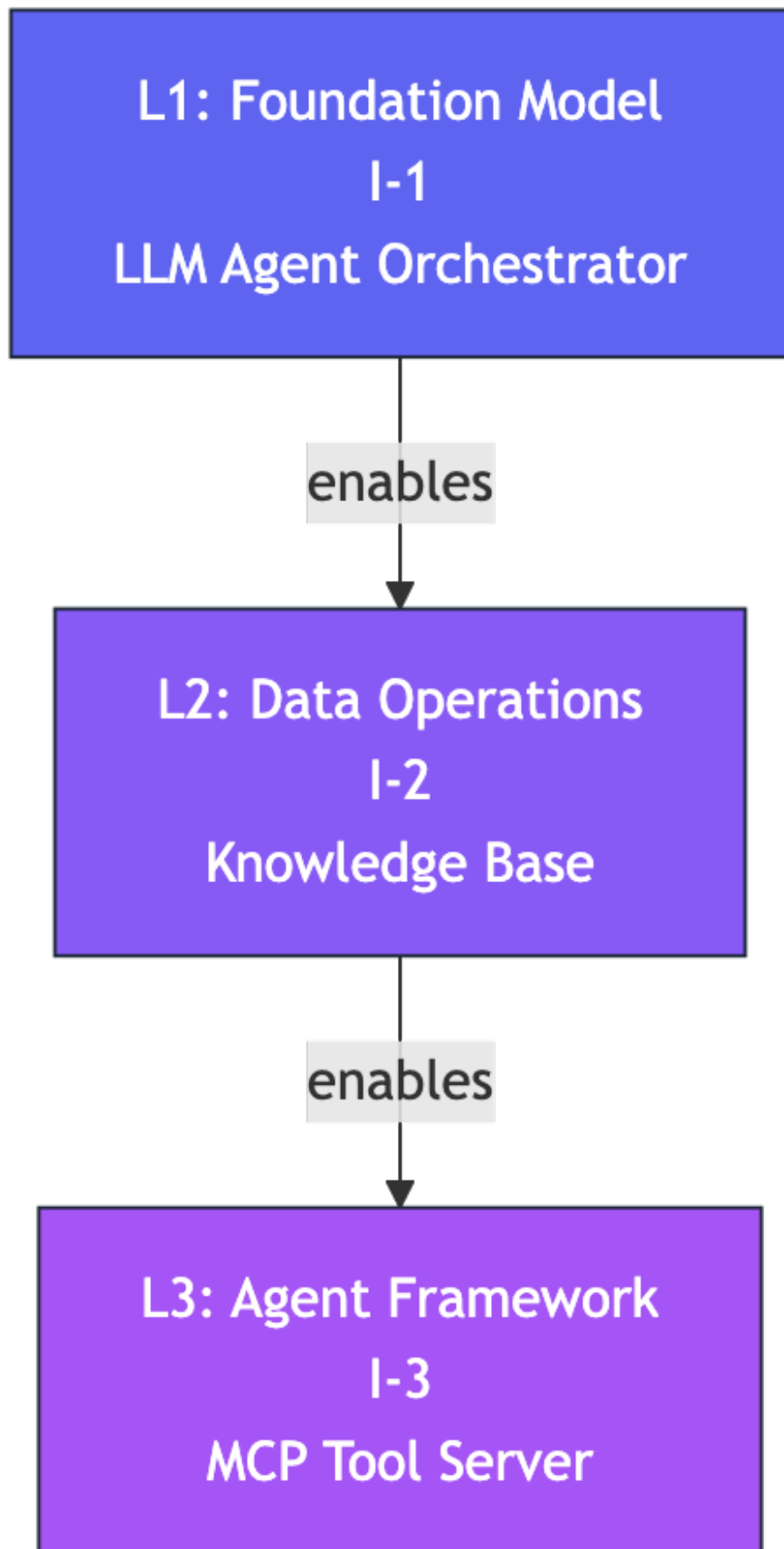
Attack Progression

The attack chain begins at the Foundation Model layer (L1), where the LLM Agent Orchestrator's context leakage vulnerability (I-1, Critical) exposes sensitive knowledge base content through model responses. When the Orchestrator fails to enforce per-user context isolation and output filtering, confidential documents retrieved during RAG operations are disclosed in model outputs. This information disclosure ****triggers**** exploitation at the Data Operations layer (L2), where insufficient access controls on the vector store (I-2) allow an attacker — now informed about the knowledge base schema and content structure — to directly query and extract document embeddings. The exposed embedding data can be reversed to reconstruct source document content, amplifying the initial leak into systematic data exfiltration. The cascade then ****triggers**** a critical infrastructure exposure at the Agent Framework layer (L3), where the MCP Tool Server's SSRF vulnerability (I-4, High) enables prompt-derived tool arguments to redirect outbound requests to cloud metadata endpoints, converting a conversational information leak into full cloud credential theft with potential lateral movement across the hosting environment.

Impacted Findings: I-1, I-2, I-4

Cross-Layer Attack Chain Analysis

CRITICAL CHAIN-002 L1 → L2 → L3 **Context Leakage Propagation: Foundation Model to Data Operations to Agent Framework**



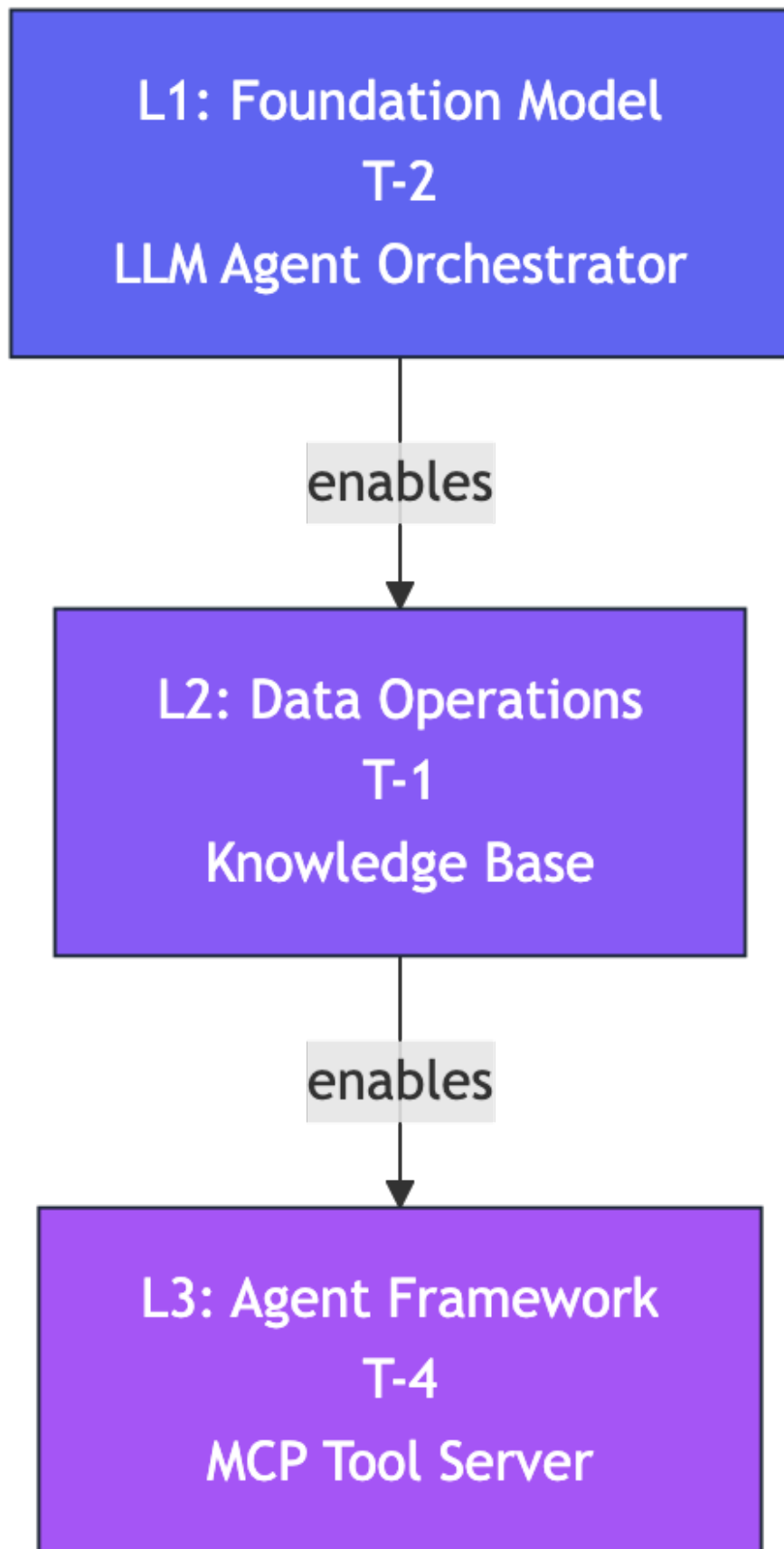
Attack Progression

The chain originates at the Foundation Model layer (L1), where the LLM Agent Orchestrator's context leakage (I-1, Critical) exposes sensitive knowledge base content in model responses due to absent output filtering and per-user context isolation. This disclosure ****triggers**** a secondary exposure at the Data Operations layer (L2) — the Knowledge Base's insufficient vector store access controls (I-2) become exploitable when an attacker leverages leaked schema information to craft targeted embedding queries, enabling reconstruction of confidential document content from extracted embeddings. The information disclosure cascade then ****triggers**** exposure at the Agent Framework layer (L3), where the MCP Tool Server returns API credentials, internal endpoint URLs, and stack traces in error responses (I-3). The combination of knowledge base schema understanding and tool server error verbosity enables an attacker to map internal service topology, identify API authentication mechanisms, and craft targeted exploitation of internal endpoints that would otherwise require privileged network access.

Impacted Findings: I-1, I-2, I-3

Cross-Layer Attack Chain Analysis

HIGH CHAIN-003 L1 → L2 → L3 **Data Pipeline Tampering: Foundation Model to Data Operations to Agent Framework**

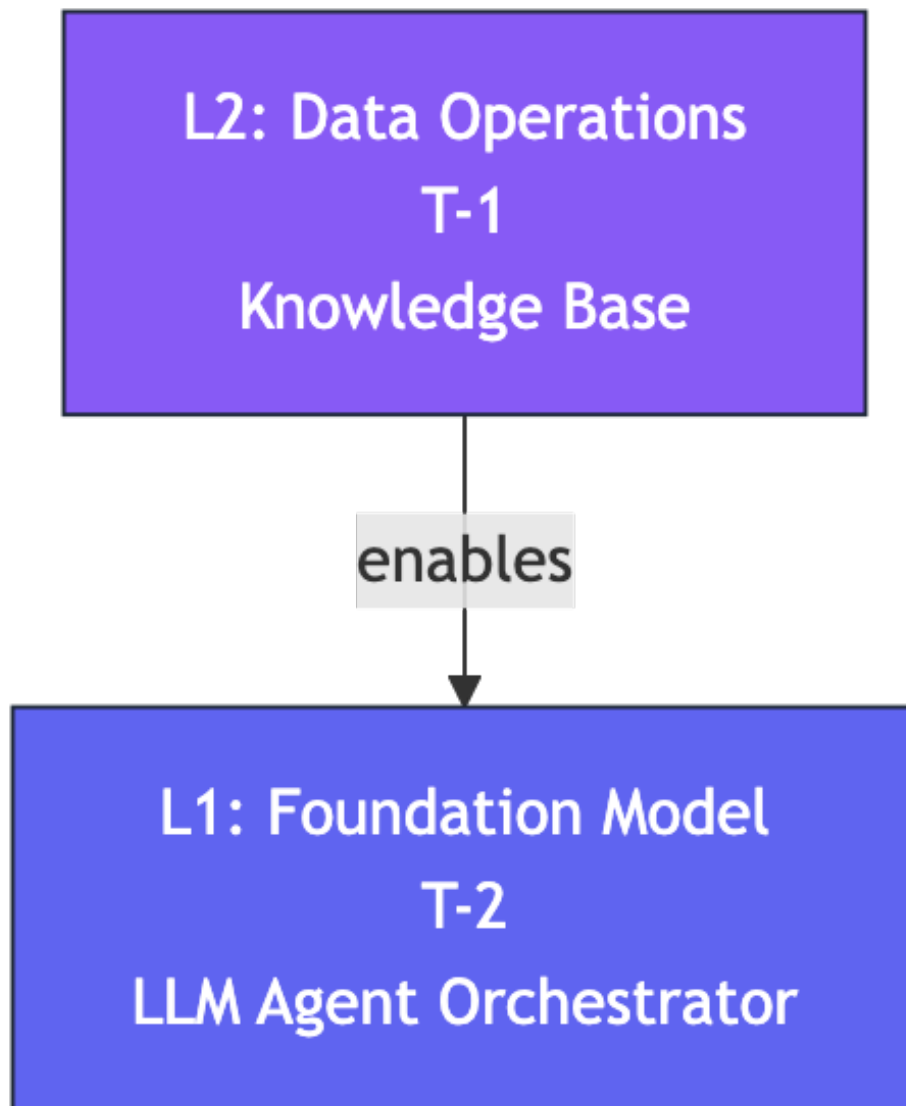


Attack Progression

This tampering chain begins at the Foundation Model layer (L1), where an attacker tampers with the LLM Agent Orchestrator's configuration or intermediate state (T-2, Medium), altering agent decision logic to produce incorrect tool call sequences or bypass safety checks. The manipulated orchestrator behavior ****triggers**** corruption at the Data Operations layer (L2), where the Knowledge Base's write access controls (T-1, High) are insufficient to prevent poisoned model outputs from corrupting document embeddings. As the orchestrator's compromised decision logic generates corrupted context retrieval queries and write operations, the vector store's integrity is systematically degraded. The data pipeline corruption then ****triggers**** exploitation at the Agent Framework layer (L3), where the MCP Tool Server's supply chain vulnerability (T-4, High) — unpinned dependencies, unsigned container images, and absent SLSA attestation — compounds the data integrity failure, enabling an attacker to achieve persistent tampering across the full Foundation Model to Agent Framework stack.

Impacted Findings: T-2, T-1, T-4

Cross-Layer Attack Chain Analysis

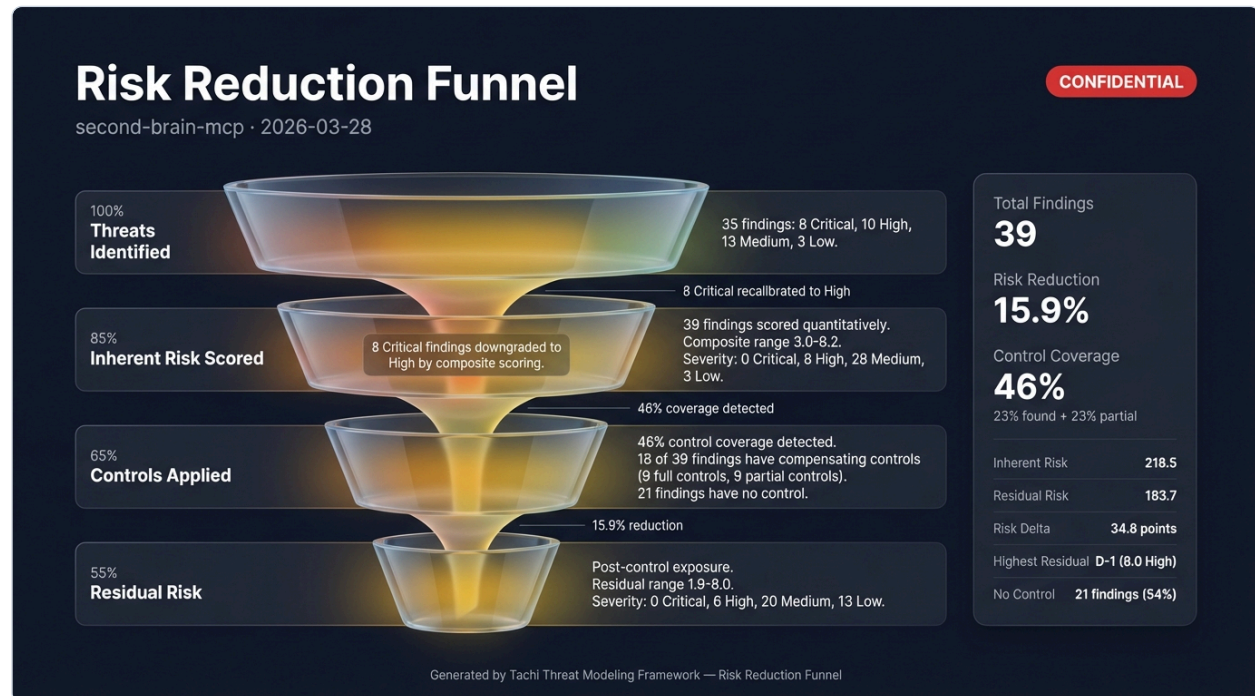
HIGH CHAIN-004 L2 → L1 **Reverse Data Poisoning: Data Operations to Foundation Model****Attack Progression**

This reverse-direction tampering chain begins at the Data Operations layer (L2), where an attacker with write access to the Knowledge Base vector store (T-1, High) injects adversarial document embeddings or modifies existing ones. The poisoned embeddings corrupt RAG retrieval results, ensuring the LLM Agent Orchestrator receives manipulated context for its reasoning. This data poisoning ****triggers**** a cascade to

the Foundation Model layer (L1), where the corrupted retrieval context causes the Orchestrator's decision logic to malfunction (T-2, Medium), producing incorrect tool call sequences or bypassing safety checks while appearing to function normally. Unlike CHAIN-003 which attacks the model configuration first, this chain exploits the data layer as the entry point, demonstrating that the bidirectional data flow between Knowledge Base and Orchestrator creates mutual attack surfaces.

Impacted Findings: T-1, T-2

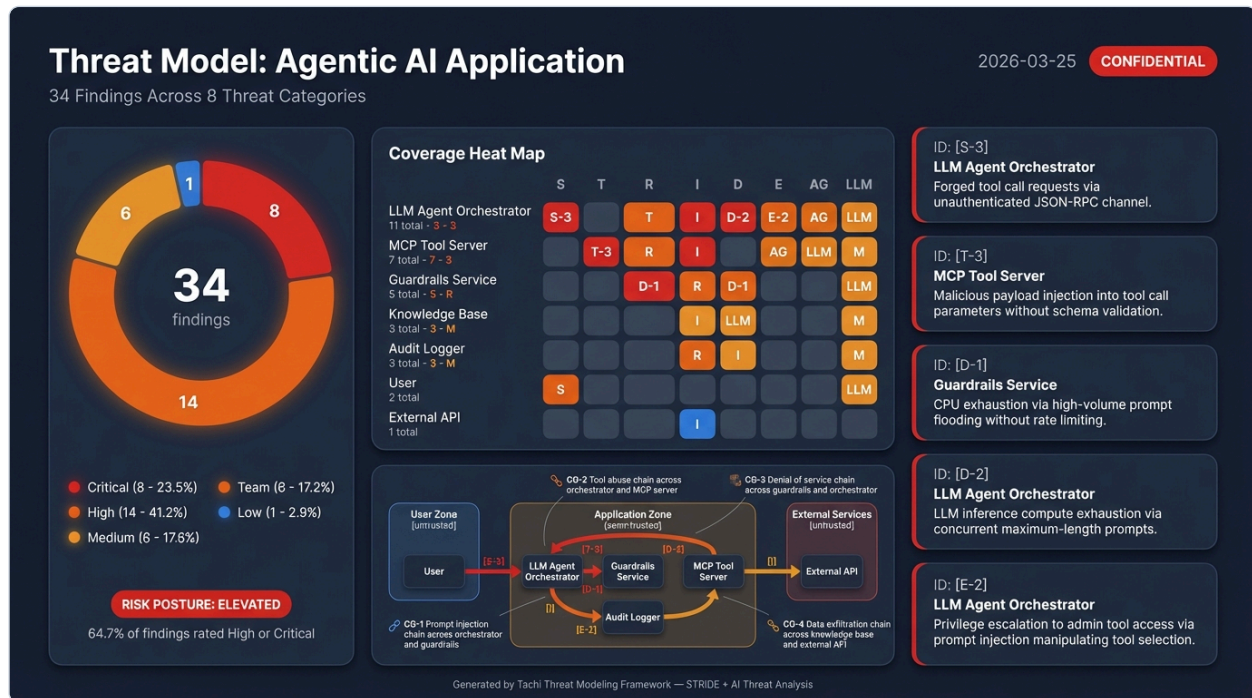
Risk Reduction Funnel



The Risk Reduction Funnel illustrates how the overall risk profile transforms through each stage of the assessment pipeline. The top tier shows all threats identified during the initial STRIDE and AI-specific threat analysis. The second tier reflects severity recalibration after quantitative scoring, where composite scores incorporating CVSS, exploitability, scalability, and reachability may shift initial severity ratings.

The third tier shows the impact of compensating controls detected in the codebase — existing mitigations that reduce effective risk. The bottom tier presents the final residual risk posture, representing the organization's actual exposure after accounting for all identified defenses. The sidebar provides key metrics at a glance, including the total risk reduction percentage, control coverage rate, and the highest-residual-risk finding requiring priority attention.

Risk Summary Dashboard



The Risk Summary Dashboard consolidates assessment results into three complementary views. The left panel displays the residual risk distribution across severity levels, showing how findings are distributed after compensating controls are applied.

The center panel presents a component-by-threat-category heat map, where each cell indicates the highest residual severity for that intersection of system component and STRIDE or AI threat category. This enables rapid identification of which components carry the highest concentration of risk. The right panel highlights the top findings by residual risk score, listing the specific threats that require the most immediate attention with their affected components and residual scores.

MAESTRO Layer Analysis

MAESTRO Layer Analysis

The following findings are grouped by their CSA MAESTRO framework architectural layer, providing a layer-oriented view of the threat landscape. Each layer represents a distinct level of the agentic AI system stack, from Foundation Model (L1) through Agent Ecosystem (L7). Findings within each layer are sorted by severity.

L1 — Foundation Model (10 findings)

ID	Component	Severity	Threat
I-1	LLM Agent Orchestrator	CRITICAL	Orchestrator leaks sensitive context from the knowledge base or prior conversation turns in its responses to the user, exposing confidential documents or other users' data
LLM-1	LLM Agent Orchestrator	CRITICAL	Indirect prompt injection via documents retrieved from the knowledge base causes the orchestrator to execute attacker-controlled instructions, exfiltrating sensitive context or invoking unauthorized tool calls
R-2	LLM Agent Orchestrator	HIGH	Orchestrator makes autonomous multi-step decisions that cannot be attributed to a specific triggering prompt or user action because decision chain logging is incomplete
E-1	LLM Agent Orchestrator	HIGH	Orchestrator escalates its own tool permissions beyond the user's authorization level by dynamically requesting elevated scopes from the MCP Tool Server, accessing tools the invoking user is not authorized to use
AG-1	LLM Agent Orchestrator	HIGH	Orchestrator autonomously escalates its own action scope by chaining multiple tool calls into a privileged operation sequence that no single tool call would permit, bypassing per-tool authorization boundaries
LLM-3	LLM Agent Orchestrator	HIGH	Attacker crafts prompts that cause the LLM to generate tool call parameters containing injection payloads (SQL, shell commands, JSON-RPC manipulation) that execute on downstream systems through the MCP Tool Server
S-2	LLM Agent Orchestrator	MEDIUM	Attacker crafts spoofed tool call responses that mimic the MCP Tool Server, injecting fabricated results into the orchestration pipeline
T-2	LLM Agent Orchestrator	MEDIUM	Attacker tampers with orchestration configuration or intermediate state to alter agent decision logic, causing the orchestrator to produce incorrect tool call sequences or bypass safety checks
AG-3	LLM Agent Orchestrator	MEDIUM	Orchestrator generates and executes multi-step plans without checkpoints, making irreversible changes across multiple tools before any human review occurs
LLM-2	LLM Agent Orchestrator	MEDIUM	Attacker poisons knowledge base documents with adversarial content designed to persistently corrupt LLM reasoning, causing the orchestrator to consistently produce incorrect or malicious outputs for specific query patterns

L2 — Data Operations (2 findings)

ID	Component	Severity	Threat
T-1	Knowledge Base	HIGH	Attacker with write access to the vector store injects or modifies document embeddings, corrupting RAG retrieval results and influencing LLM output
I-2	Knowledge Base	MEDIUM	Unauthorized access to vector store contents exposes confidential document embeddings that can be reversed to reconstruct source document content

L3 — Agent Framework (5 findings)

ID	Component	Severity	Threat
D-2	MCP Tool Server	HIGH	Attacker triggers recursive or excessively long tool call chains through crafted prompts, exhausting tool server resources and causing cascading timeouts across the application
AG-2	MCP Tool Server	HIGH	Attacker manipulates prompt context to cause the tool server to invoke tools outside the intended scope, executing unauthorized file system operations, network calls, or data mutations
AG-4	MCP Tool Server	HIGH	Compromised or manipulated agent triggers excessive tool invocations in rapid succession, exhausting external API quotas, compute resources, and downstream service capacity
S-3	External API	MEDIUM	Compromised or spoofed external API returns malicious payloads masquerading as legitimate API responses
I-3	MCP Tool Server	MEDIUM	Tool server includes API credentials, internal endpoint URLs, or stack traces in error responses returned to the orchestrator, which may propagate to the user

L5 — Evaluation and Observability (1 finding)

ID	Component	Severity	Threat
T-3	Audit Logger	MEDIUM	Attacker with elevated access modifies or truncates audit log entries to conceal malicious activity or alter the forensic record

L6 — Security and Compliance (2 findings)

ID	Component	Severity	Threat
D-1	Guardrails Service	HIGH	Attacker floods the guardrails service with complex prompts designed to maximize validation processing time, exhausting CPU and blocking legitimate requests
E-2	Guardrails Service	HIGH	Attacker bypasses guardrails validation through prompt obfuscation techniques (encoding, unicode manipulation, payload splitting) to access restricted orchestrator capabilities

L7 — Agent Ecosystem (2 findings)

ID	Component	Severity	Threat
S-1	User	HIGH	Attacker spoofs a legitimate user identity by stealing or replaying session tokens to submit unauthorized prompts
R-1	User	MEDIUM	User denies submitting a harmful or policy-violating prompt because session logs lack sufficient attribution to tie the prompt to a specific authenticated identity

22 findings across 6 MAESTRO layers | Sorted by severity (critical first)

Detailed Findings

Findings Detail — Residual Risk

Findings Detail — Residual Risk

HIGH LLM-1

LLM Agent Orchestrator

Indirect prompt injection via documents retrieved from the ...

█

Residual: 8.1 | Control: No Control Found

HIGH AG-4

MCP Tool Server

Compromised or manipulated agent triggers excessive tool in...

█

Residual: 8.0 | Control: No Control Found

HIGH E-2

Guardrails Service

Attacker bypasses guardrails validation through prompt obfu...

█

Residual: 7.7 | Control: No Control Found

HIGH E-1

LLM Agent Orchestrator

Orchestrator escalates its own tool permissions beyond the ...

█

Residual: 7.5 | Control: No Control Found

HIGH LLM-3

LLM Agent Orchestrator

Attacker crafts prompts that cause the LLM to generate tool...

█

Residual: 7.5 | Control: No Control Found

HIGH AG-2

MCP Tool Server

Attacker manipulates prompt context to cause the tool serve...

I

Residual: 7.4 | Control: No Control Found

HIGH D-1

Guardrails Service

Attacker floods the guardrails service with complex prompts...

I

Residual: 7.4 | Control: No Control Found

HIGH S-1

User

Attacker spoofs a legitimate user identity by stealing or r...

I

Residual: 7.4 | Control: No Control Found

HIGH S-3

External API

Compromised or spoofed external API returns malicious paylo...

I

Residual: 7.4 | Control: No Control Found

HIGH AG-1

LLM Agent Orchestrator

Orchestrator autonomously escalates its own action scope by...

I

Residual: 7.3 | Control: No Control Found

MEDIUM LLM-2

LLM Agent Orchestrator

Attacker poisons knowledge base documents with adversarial ...

I

Residual: 6.9 | Control: No Control Found

MEDIUM AG-3

LLM Agent Orchestrator

Orchestrator generates and executes multi-step plans without...

█

Residual: 6.7 | Control: No Control Found

MEDIUM D-2

MCP Tool Server

Attacker triggers recursive or excessively long tool call c...

█

Residual: 6.7 | Control: No Control Found

MEDIUM I-1

LLM Agent Orchestrator

Orchestrator leaks sensitive context from the knowledge bas...

█

Residual: 6.7 | Control: No Control Found

MEDIUM I-3

MCP Tool Server

Tool server includes API credentials, internal endpoint URL...

█

Residual: 6.2 | Control: No Control Found

MEDIUM T-1

Knowledge Base

Attacker with write access to the vector store injects or m...

█

Residual: 6.1 | Control: No Control Found

MEDIUM S-2

LLM Agent Orchestrator

Attacker crafts spoofed tool call responses that mimic the ...

█

Residual: 6.0 | Control: No Control Found

MEDIUM R-1	User
User denies submitting a harmful or policy-violating prompt... █ Residual: 5.8 Control: No Control Found	
MEDIUM T-2	LLM Agent Orchestrator
Attacker tampers with orchestration configuration or interm... █ Residual: 5.7 Control: No Control Found	
MEDIUM I-2	Knowledge Base
Unauthorized access to vector store contents exposes confid... █ Residual: 5.3 Control: No Control Found	
MEDIUM T-3	Audit Logger
Attacker with elevated access modifies or truncates audit l... █ Residual: 5.3 Control: No Control Found	
MEDIUM R-2	LLM Agent Orchestrator
Orchestrator makes autonomous multi-step decisions that can... █ Residual: 5.0 Control: No Control Found	

22 findings | Sorted by residual severity (critical first)

Control Coverage

Control Status by STRIDE Category

STRIDE Category	Found	Partial	Missing	Total
Spoofing	0	0	3	3
Tampering	0	0	3	3
Repudiation	0	0	2	2
Information Disclosure	0	0	3	3
Denial of Service	0	0	2	2
Elevation of Privilege	0	0	2	2
Agentic Threats	0	0	4	4
LLM Threats	0	0	3	3

Coverage Summary

Control Status	Count	Percentage
Control Found	0	0%
Partial Control	0	0%
No Control Found	22	100%
Total	22	100%

Remediation Roadmap

■ Critical: 0 ■ High: 10 ■ Medium: 12 ■ Low: 0

22 total actions

Priority	Finding	Recommendation	SLA	Status
HIGH				
10 actions				
LLM-1	Indirect prompt injection via documents retrieved from the ...		14d	No Control Found
AG-4	Compromised or manipulated agent triggers excessive tool in...		14d	No Control Found
E-2	Attacker bypasses guardrails validation through prompt obfu...		14d	No Control Found
E-1	Orchestrator escalates its own tool permissions beyond the ...		14d	No Control Found
LLM-3	Attacker crafts prompts that cause the LLM to generate tool...		14d	No Control Found
AG-2	Attacker manipulates prompt context to cause the tool serve...		14d	No Control Found
D-1	Attacker floods the guardrails service with complex prompts...		14d	No Control Found
S-1	Attacker spoofs a legitimate user identity by stealing or r...		14d	No Control Found
S-3	Compromised or spoofed external API returns malicious paylo...		14d	No Control Found
AG-1	Orchestrator autonomously escalates its own action scope by...		14d	No Control Found
MEDIUM				
12 actions				
LLM-2	Attacker poisons knowledge base documents with adversarial ...		30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
AG-3	Orchestrator generates and executes multi-step plans without...		30d	No Control Found
D-2	Attacker triggers recursive or excessively long tool call c...		30d	No Control Found
I-1	Orchestrator leaks sensitive context from the knowledge bas...		30d	No Control Found
I-3	Tool server includes API credentials, internal endpoint URL...		30d	No Control Found
T-1	Attacker with write access to the vector store injects or m...		30d	No Control Found
S-2	Attacker crafts spoofed tool call responses that mimic the ...		30d	No Control Found
R-1	User denies submitting a harmful or policy-violating prompt...		30d	No Control Found
T-2	Attacker tampers with orchestration configuration or interm...		30d	No Control Found
I-2	Unauthorized access to vector store contents exposes confid...		30d	No Control Found
T-3	Attacker with elevated access modifies or truncates audit l...		30d	No Control Found
R-2	Orchestrator makes autonomous multi-step decisions that can...		30d	No Control Found